

THREAT ADVISORY



ATTACK REPORT

**Iranian hackers leveraged
Log4Shell to penetrate US federal
agency**

Date of Publication

November 17, 2022

Admiralty Code

A1

TA Number

TA2022261

Summary

Date: April 2022

Attack Region: Australia, Austria, Finland, France, Germany, Hungary, Israel, Italy, Kuwait, Lebanon, Malaysia, Poland, Saudi Arabia, UAE, USA.

Targeted Industry: Aviation, Chemical, Energy, Defense, Engineering, Financial, Government, Healthcare, IT, Media, Manufacturing, Oil and gas, Retail, Telecommunications.

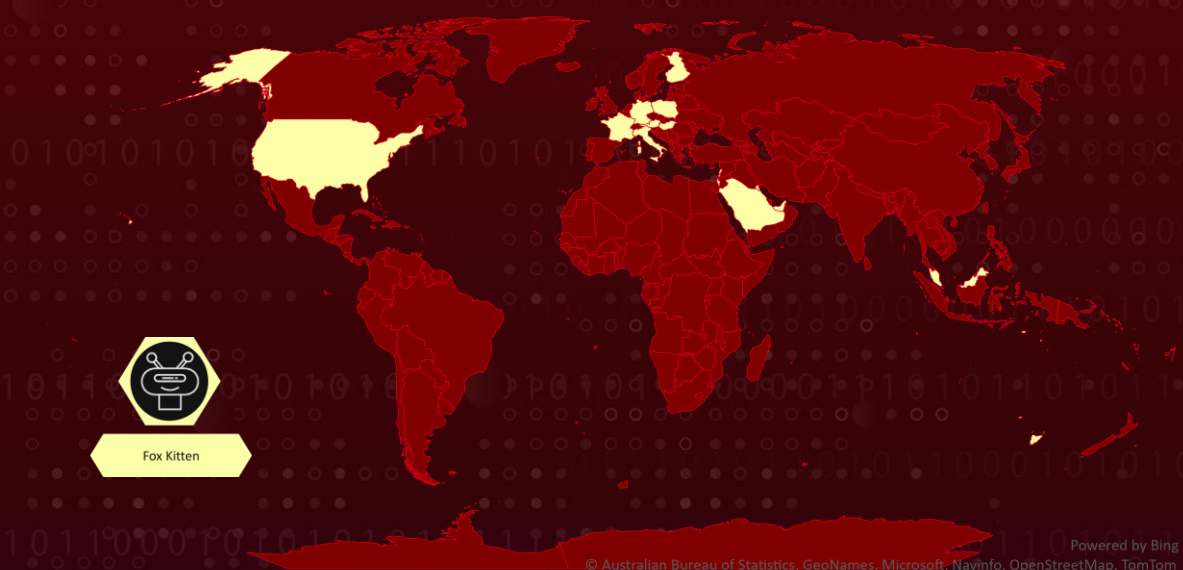
Threat Actor: Fox Kitten

Attack: Log4Shell was exploited to deploy the XMRig cryptocurrency miner.

🔧 CVE Table

CVE	NAME	PATCH
CVE-2021-44228	Apache Log4j Remote Code Execution Vulnerabilities	✓

🗡️ Attack Regions



Attack Details

#1

Iranian APT activity was detected on the networks of federal agencies. The intruders utilized an exploit targeting Log4Shell (CVE-2021-44228) to install XMRig crypto mining software on an unpatched VMware Horizon server. Due to the similarity in the tools used and attack chain hive pro threat research team has linked it to the Iranian state-sponsored actor Fox Kitten

#2

Following initial access, the attacker migrated laterally, targeting the domain controller (DC), stealing credentials, and installing Ngrok reverse proxies on multiple hosts to maintain persistence.

#3

After the threat actors established a firm traction in the network and migrated laterally to the domain controller, they executed the PowerShell command on Active Directory to get a list of all the devices connected to the domain.

Recommendations



Security Leaders

Phishing simulations and routine education and awareness training and communications rarely account for MFA fatigue and web browser hygiene. Integrate and communicate all lessons learned.



Security Engineers

- **Uni5 Users:** This is an actionable threat advisory in HivePro Uni5. Prioritize and block all indicators attributed to the threat actors and attacks through your Command Center. Test your controls with Uni5's Breach & Attack Simulation.
- **All Engineers:** Refer to and action upon the 'Potential MITRE ATT&CK TTPs' & 'Indicators of Compromise (IoC)' on the following pages.

Potential MITRE ATT&CK TTPs

<u>TA0001</u> Initial Access	<u>TA0002</u> Execution	<u>TA0003</u> Persistence	<u>TA0005</u> Defense Evasion
<u>TA0006</u> Credential Access	<u>TA0007</u> Discovery	<u>TA0008</u> Lateral Movement	<u>TA0011</u> Command and Control
<u>T1190</u> Exploit Public-Facing Application	<u>T1078</u> Valid Accounts	<u>T1078.001</u> Default Accounts	<u>T1059</u> Command and Scripting Interpreter
<u>T1059.001</u> PowerShell	<u>T1053</u> Scheduled Task/Job	<u>T1053.005</u> Scheduled Task	<u>T1098</u> Account Manipulation
<u>T1136</u> Create Account	<u>T1136.002</u> Domain Account	<u>T1136.001</u> Local Account	<u>T1562</u> Impair Defenses
<u>T1562.001</u> Disable or Modify Tools	<u>T1070</u> Indicator Removal	<u>T1070.004</u> File Deletion	<u>T1555</u> Credentials from Password Stores
<u>T1003</u> OS Credential Dumping	<u>T1003.001</u> LSASS Memory	<u>T1018</u> Remote System Discovery	<u>T1016</u> System Network Configuration Discovery
<u>T1016.001</u> Internet Connection Discovery	<u>T1021</u> Remote Services	<u>T1021.001</u> Remote Desktop Protocol	<u>T1105</u> Ingress Tool Transfer
<u>T1090</u> Proxy			

🔪 Indicator of Compromise (IOC)

TYPE	VALUE
Domains	tunnel.us.ngrok[.]com korgn.su.lennut[.]com
IP Addresses	51.89.181[.]64 182.54.217[.]2 144.76.136[.]153

🔪 Patch Links

<https://kb.vmware.com/s/article/87073>

<https://www.vmware.com/security/advisories/VMSA-2021-0028.html>

🔪 References

<https://www.cisa.gov/uscert/ncas/alerts/aa22-320a>

<https://www.bleepingcomputer.com/news/security/us-govt-iranian-hackers-breached-federal-agency-using-log4shell-exploit/>

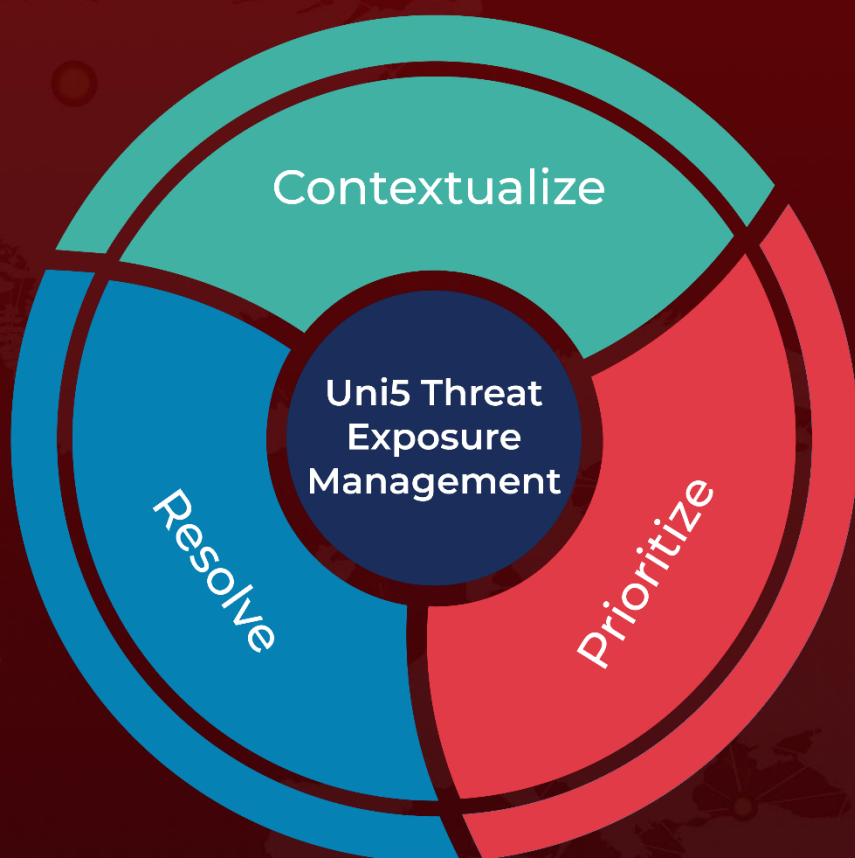
<https://attack.mitre.org/groups/G0117/>

<https://attack.mitre.org/software/S0508/>

What Next?

At **HivePro**, it is our mission to detect the most likely threats to your organization and to help you prevent them from happening.

Book a free demo with **Hive Pro Uni5**: Continuous Threat Exposure Management Platform.



REPORT GENERATED ON

November 17, 2022 • 1:37 AM

© 2022 All Rights are Reserved by HivePro



More at www.hivepro.com